API SECURITY RISK ANALYSIS REPORT

Task 3 – Cyber Security Internship
Future Interns

Prepared by: Sohel Mujawar
Role: Cyber Security Intern
Tools Used: Postman, Kali Linux
API Tested: ReqRes Public Test API (https://reqres.in)
Assessment Type: Read-Only Security Risk Analysis

---

1. Executive Summary

This report presents the findings of a structured API Security Risk Analysis conducted on a public demo API endpoint. The objective of this assessment was to analyze API behavior, authentication requirements, response headers, and exposed metadata from a security perspective without performing exploitation.

The assessment focused on identifying potential misconfigurations, excessive data exposure, authentication gaps, and infrastructure disclosures that may present security risks in real-world SaaS environments.

The testing was performed using Postman in a controlled environment under read-only scope.

---

2. Objective

The primary objectives of this assessment were:

- To analyze public API endpoints
- To inspect authentication and access requirements
- To review response headers and metadata
- To identify potential security risks
- To classify risk severity
- To provide clear remediation recommendations

This assessment was conducted ethically and did not involve exploitation attempts.

---

3. Scope & Limitations

In Scope:

- Public demo APIs (ReqRes)
- GET requests (read-only)
- Response header analysis

- Authentication observation

Out of Scope:

- Exploitation attempts
- Denial-of-Service testing
- Authentication bypass attacks
- Attacking private systems

---

4. Methodology

The following methodology was followed:

Step 1: API Documentation Review
Reviewed publicly available API documentation to understand endpoints and expected responses.

Step 2: Endpoint Testing
Performed GET requests using Postman to observe API responses and status codes.

Step 3: Header Inspection
Analyzed response headers to identify server details, technology stack disclosures, CORS configuration, and rate limiting indicators.

Step 4: Authentication Observation
Checked whether endpoints required authentication tokens or allowed unauthenticated access.

Step 5: Risk Classification
Each identified issue was categorized as Low, Medium, or High based on potential business impact.

---

5. Findings & Risk Analysis

Finding 1: Unauthenticated Public Endpoints
Description:
The tested endpoints responded successfully without requiring authentication tokens.

Risk Level: Medium

Business Impact:
In production environments, unauthenticated access to user-related data may lead to data scraping, unauthorized access, or compliance violations.

Recommendation:
Implement authentication mechanisms such as OAuth 2.0 or JWT-based token validation for sensitive endpoints.

Finding 2: Infrastructure Information Disclosure
Description:
Response headers revealed technology-related details such as server information and framework indicators.

Risk Level: Low

Business Impact:
Technology stack exposure may assist attackers in fingerprinting infrastructure and targeting known vulnerabilities.

Recommendation:
Minimize unnecessary header disclosures and remove non-essential server identification details.

Finding 3: CORS Header Configuration Observation
Description:
Access-Control related headers were present in responses. Although no direct misconfiguration was exploited, CORS policies must be carefully configured in production environments.

Risk Level: Low

Business Impact:
Improper CORS configuration in production systems may allow unauthorized cross-origin data access.

Recommendation:
Restrict allowed origins to trusted domains and avoid wildcard configurations in production.

Finding 4: Rate Limiting Indicators Present
Description:
Rate limiting headers were observed in responses, indicating basic abuse prevention controls.

Risk Level: Informational

Business Impact:
Rate limiting helps prevent API abuse and automated attacks.

Recommendation:
Ensure strict rate limiting and monitoring mechanisms are applied in production APIs.

6. Risk Severity Summary

Low Risk:

- Infrastructure disclosure via headers
- CORS configuration observation

Medium Risk:

- Unauthenticated endpoint access (if sensitive data exists in production)

Informational:

- Presence of rate limiting controls

---

7. Business Impact Analysis

If similar configurations exist in production systems handling sensitive data, the following risks may occur:

- Data scraping
- Exposure of user information
- Infrastructure fingerprinting
- Increased attack surface visibility

Even minor metadata disclosures can contribute to targeted attacks when combined with other vulnerabilities.

---

8. Remediation Strategy

To improve API security posture, organizations should:

- Implement strong authentication and authorization controls
- Use role-based access control (RBAC)
- Minimize response data to only required fields
- Remove unnecessary response headers
- Enforce strict CORS policies
- Apply rate limiting and monitoring
- Follow OWASP API Security Top 10 guidelines

---

9. Conclusion

This API Security Risk Analysis demonstrated the importance of reviewing API endpoints from a defensive security perspective. While the tested API was a public demo system, the analysis highlights how small misconfigurations in real SaaS applications can translate into significant business risks.

The assessment strengthened practical understanding of API inspection, response validation, infrastructure fingerprinting, and structured security reporting.